

Progetto S9/L5

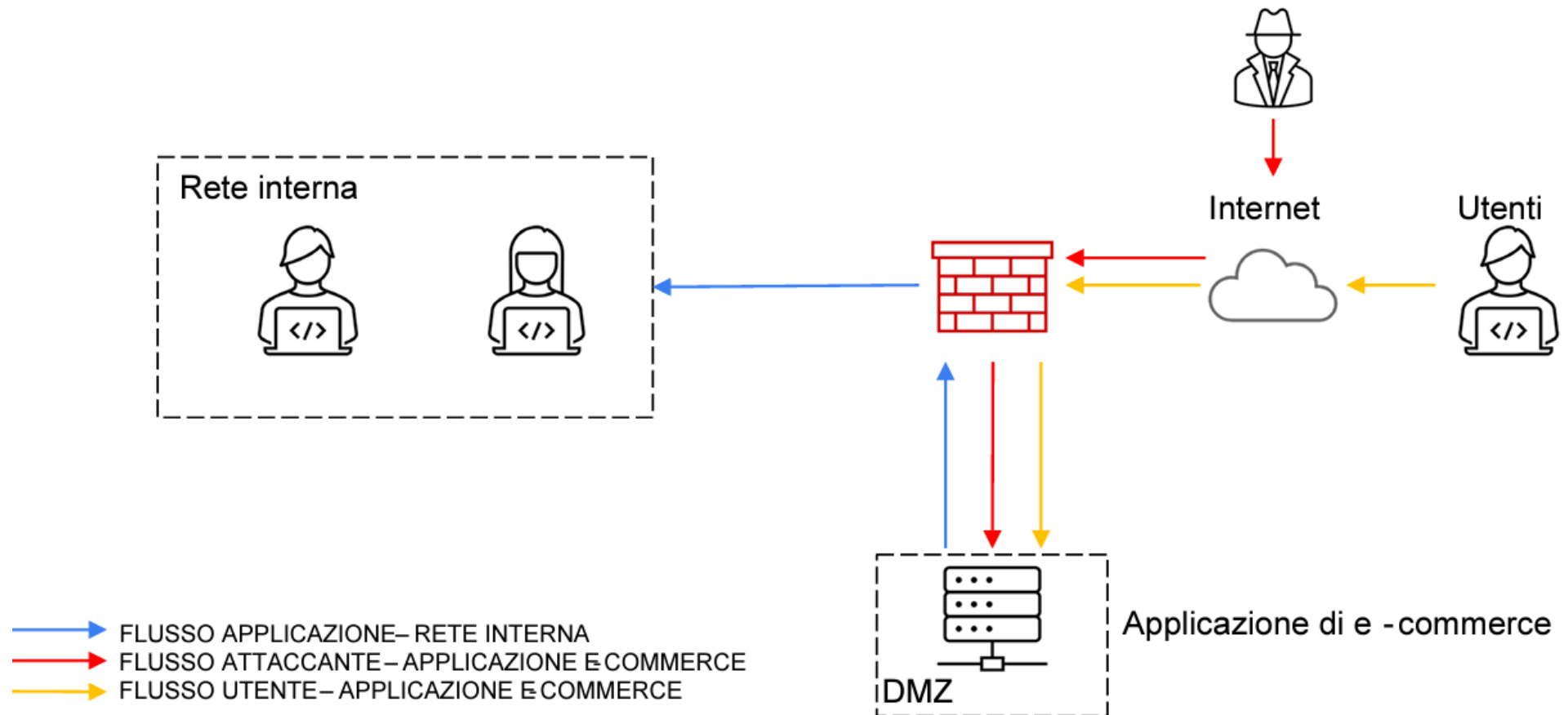
Analisi dei Log

Esercizio traccia e requisiti

Con riferimento alla figura in slide 2, rispondere ai seguenti quesiti.

1. **Azioni preventive:** quali azioni preventive si potrebbero implementare per difendere l'applicazione Web da attacchi di tipo SQLi oppure XSS da parte di un utente malintenzionato? Modificate la figura in modo da evidenziare le implementazioni. È richiesta sola modifica
2. **Impatti sul business:** l'applicazione Web subisce un attacco di tipo DDoS dall'esterno che rende l'applicazione non raggiungibile per 10 minuti. Calcolare l'impatto sul business dovuto alla non raggiungibilità del servizio, considerando che in media minuto gli utenti spendono ogni 1.200 € sulla piattaforma di e-commerce. Fare eventuali valutazioni di azioni preventive che si possono applicare in questa problematica
3. **Response:** l'applicazione Web viene infettata da un malware. La vostra priorità è che il malware non si propaghi sulla vostra rete, mentre non siete interessati a rimuovere l'accesso da parte dell'attaccante alla macchina infettata. Modificate la figura in slide 2 con la soluzione proposta.
4. **Soluzione completa:** unire i disegni dell'azione preventiva e della response (unire soluzione 1 e 3)
5. **Modifica «più aggressiva» dell'infrastruttura:** anche una soluzione al punto 2) integrando eventuali altri elementi di sicurezza (integrando Budget 5000-10000 euro. Eventualmente fare più proposte di spesa.

Architettura di rete: L'applicazione di e-commerce deve essere disponibile per gli utenti tramite sulla piattaforma. La rete interna è raggiungibile dalla DMZ per via delle policy sul firewall; quindi, se il server in DMZ venisse compromesso potenzialmente un attaccante potrebbe raggiungere la rete interna.

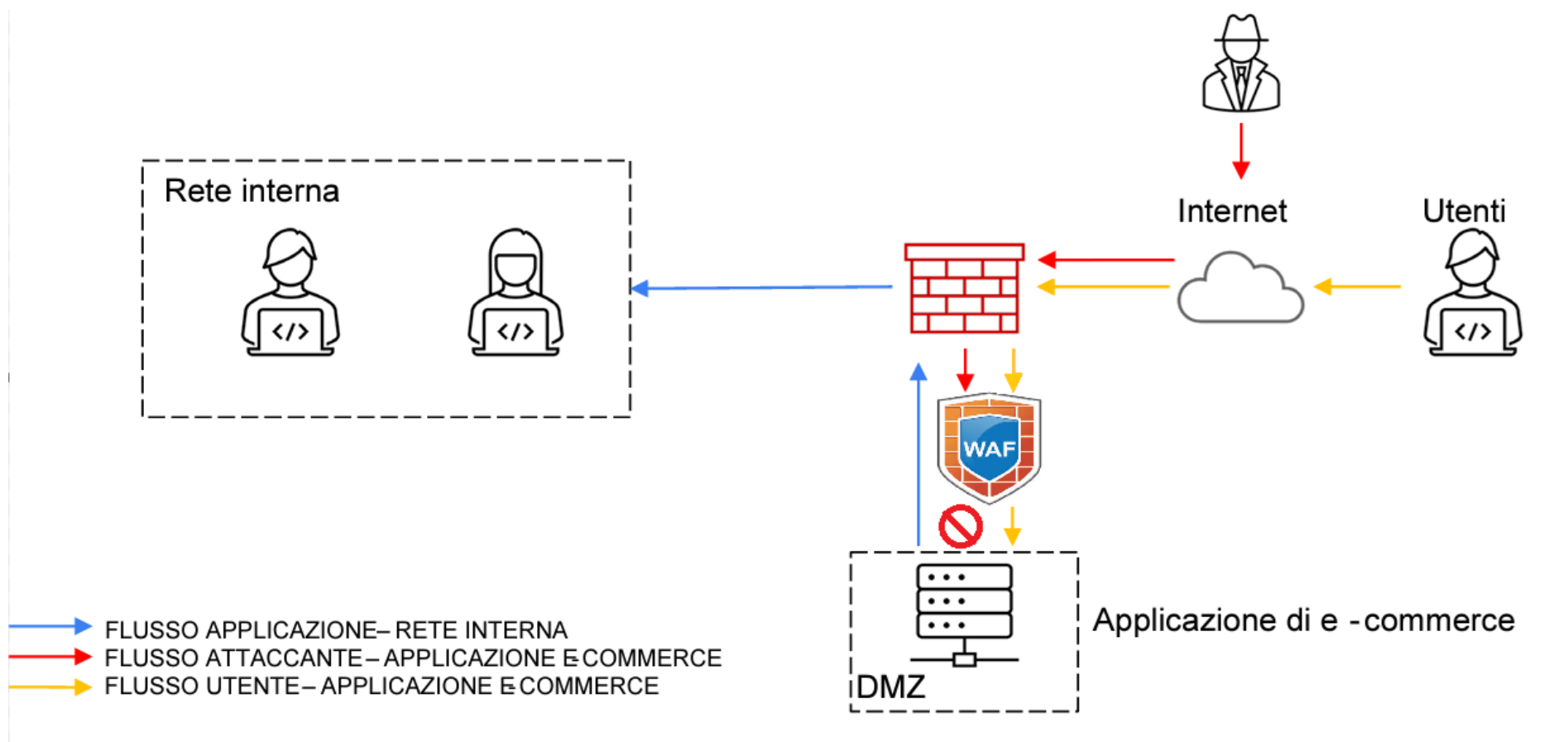


1 - Difesa contro SQL Injection e XSS

Per prevenire attacchi SQL Injection e Cross-Site Scripting (XSS) da un punto di vista strutturale possiamo usare un **Web Application Firewall (WAF)**.

Un WAF è una soluzione che filtra e monitora il traffico HTTP tra un'applicazione web e Internet proteggendo le applicazioni web da attacchi comuni come SQL Injection e XSS bloccando le richieste dannose. Nel caso di SQL Injection il WAF analizza le richieste in ingresso e in uscita per identificare e bloccare schemi di attacco noti e input sospetti che potrebbero contenere codice SQL dannoso; Per gli attacchi XSS il WAF rileva e blocca tentativi di iniezione di script dannosi nei contenuti delle pagine web, impedendo che questi vengano eseguiti nel browser degli utenti.

Un possibile WAF da implementare può essere Cloudflare WAF che fornisce protezione per applicazioni web su qualsiasi piattaforma. Se si preferisce una soluzione open-source si può optare per ModSecurity che può essere integrato con vari server web come Apache, Nginx e IIS.



2 - Impatti sul business e azioni preventiva

Sappiamo che l'applicazione Web non è raggiungibile per 10 minuti, che possiamo indicare con una variabile che chiamerò arbitrariamente **DT** (Down Time). Inoltre, scopriamo che in media ogni minuto gli utenti spendono 1.200 € sulla piattaforma, che possiamo indicare con **CPM** (Cost Per Minute) anch'essa chiamata così arbitrariamente.

Ora possiamo calcolarci la perdita prodotta dall'attacco DDoS.

Impact = $DT * CPM = 10 * 1200 = 12.000 \text{ €}$

L'azienda ha perso 12.000 € per 10 minuti di inattività.

Come possiamo impedire che ciò riaccada? Quali azioni preventive possiamo adottare?

La strategia principale è la **resilienza dei sistemi**.

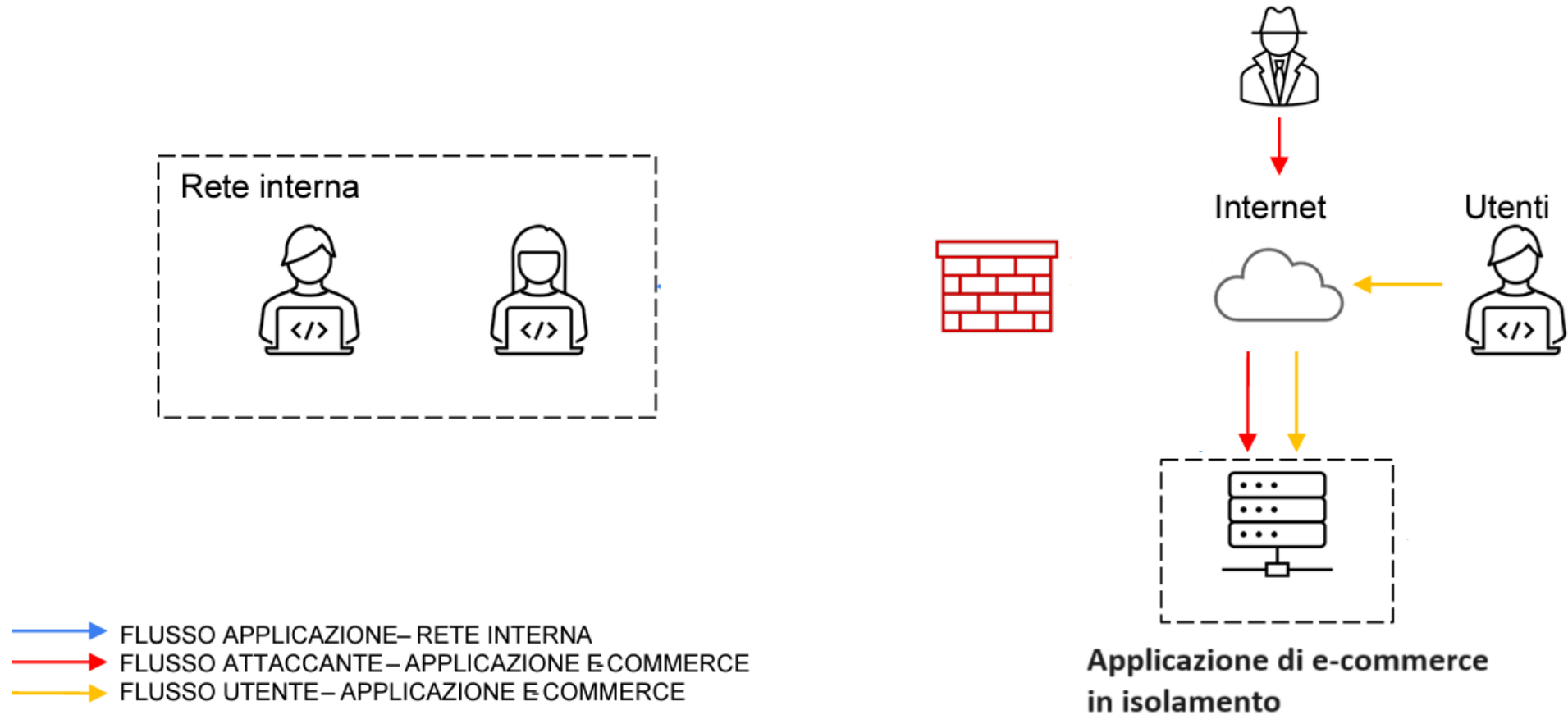
Con resilienza di un sistema si intende la sua capacità di far fronte a determinati eventi critici andando ad eliminare i cosiddetti «**single point of failure**» (SPOF). Il SPOF è una parte del sistema il cui malfunzionamento può portare ad anomalie o addirittura alla cessazione del servizio da parte del sistema (come in questo caso) e va a minare uno dei principi cardine della triade CIA (Availability, Disponibilità del servizio). Quindi dobbiamo usare delle **ridondanze** nel sistema per assicurarne la resilienza. Per farlo, possiamo usare vari strumenti in combinazione come **failover cluster** e **WAF**.

I failover cluster migliorano la disponibilità e l'affidabilità dei servizi distribuendo il carico di lavoro su più server. Purtroppo, non basta per difendersi da un attacco DDoS. I failover cluster aiutano con ridondanza e scalabilità permettendo di gestire meglio un attacco DDoS, ma se quest'ultimo fosse abbastanza importante potrebbe comunque soverchiare l'infrastruttura. Per questo dobbiamo usare un WAF configurato con **Content Delivery Network (CDN)**, che aiuta a distribuire il contenuto dell'applicazione web su una rete globale di server; **Rate Limiting** che controlla il numero di richieste che un singolo IP può effettuare in un determinato periodo di tempo; e **Filtri IP** che bloccano o consentono il traffico basato sugli indirizzi IP, permettendo di prevenire accessi non autorizzati e mitigare attacchi DDoS.

3 – Response

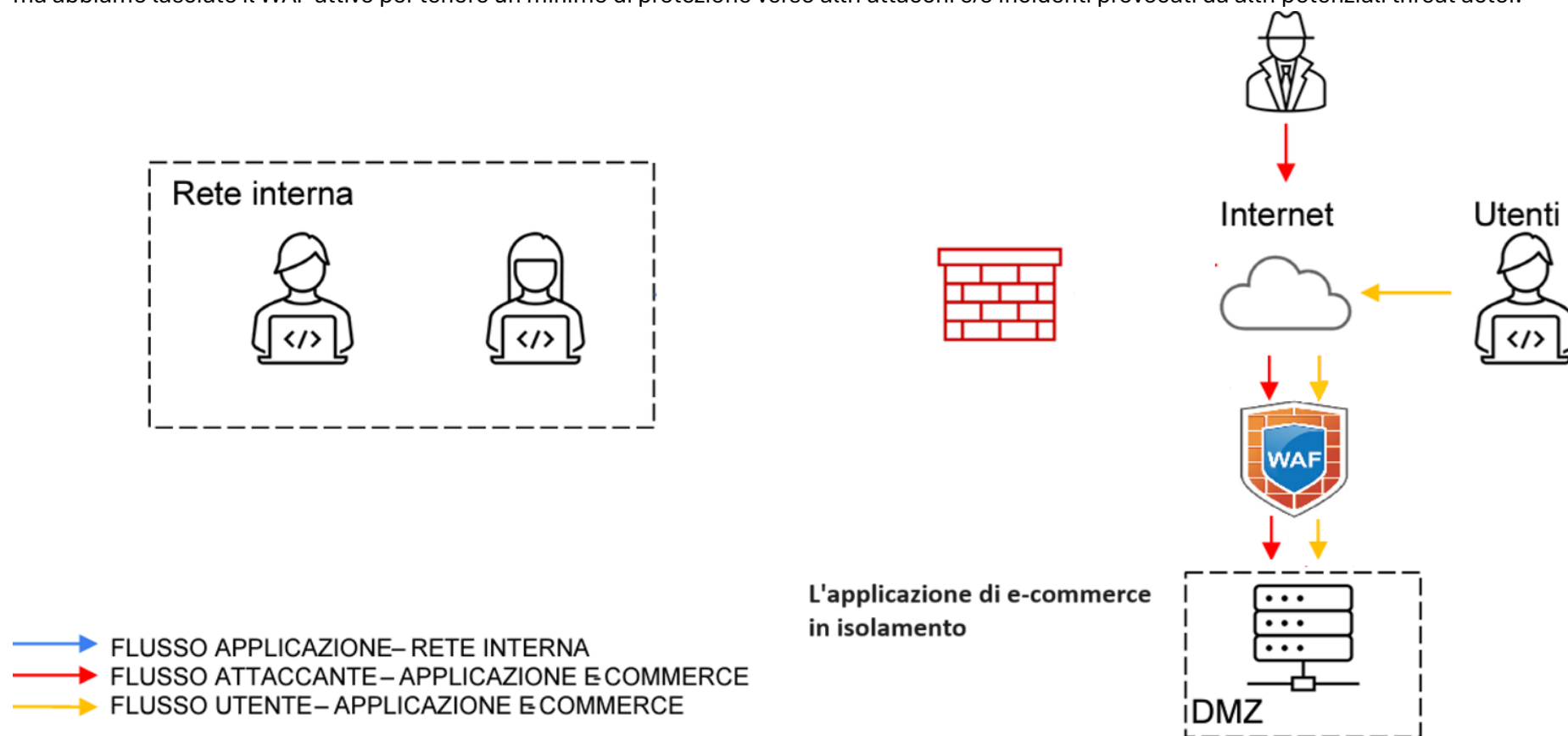
In questo scenario, dove la priorità è impedire che il malware si propaghi sulla rete interna senza rimuovere l'accesso dell'attaccante alla macchina infettata, possiamo implementare un processo di contenimento di tipo **isolamento**.

Utilizziamo la tecnica di **segmentazione della rete** per isolare la macchina infetta dal resto della rete interna. Ciò può essere fatto spostando la macchina in una VLAN separata o utilizzando un firewall per bloccare la comunicazione tra la macchina infetta e altre parti della rete.



4 - Soluzione completa

In questo caso, l'attaccante è riuscito a penetrare il Firewall perimetrale e il WAF. Per questo motivo abbiamo isolato l'asset infettato dalla rete interna, ma abbiamo lasciato il WAF attivo per tenere un minimo di protezione verso altri attacchi e/o incidenti provocati da altri potenziali threat actor.



5 - Modifica «più aggressiva» dell'infrastruttura

Per migliorare l'infrastruttura della rete ho ideato due proposte con budget differenti cercando di rimanere in linea con i mezzi economici disponibili.

Soluzione ideale

WAF per protezione delle applicazioni web specifiche e sui loro dati.

Un secondo server per garantire ridondanza nel sistema.

Servizi di Backup Cloud per salvaguardare i dati aziendali e facilitare la recovery.

SIEM per monitorare la rete analizzando i file di log.

SOAR per intervenire rapidamente sulla minacce. Essendo il SOAR una soluzione costosa possiamo optare per uno open source come **TheHive**.

Sebbene il software sia gratuito, necessità di un server mid-range tipico.

Nota: Se il Firewall perimetrale non è di tipo **NGFW** si consiglia di acquistarne uno. Questo perché i NGFW integrano vari tool di sicurezza come IDS/IPS.

CloudFlare Enterprise (WAF)	2000€/mese
Server Failover:	2000€
Servizi di Backup Cloud	1000€
Splunk SIEM:	2000€/anno
SOAR TheHive:	2000€*
Fortinet FortiGate 30E (NGFW):	1800€**
Costo Totale:	10800€

Soluzione budget

Per contenere i costi tenendo comunque come riferimento la soluzione ideale, possiamo eliminare, per quanto sconsigliato, i servizi di SIEM e SOAR.

WAF CloudFlare Enterprise	2000€/mese
Server Failover:	2000€
Servizi di Backup Cloud	1000€
NGFW Fortinet FortiGate 30E:	1800€**
Costo Totale:	6800€

* Da tenere in considerazione i costi di addestramento personale e manutenzione

** Solo se non si dispone già di una soluzione simile

BONUS

Analizzare le seguenti segnalazioni caricate su anyrun e fare un piccolo report di ciò che si scopre relativo all'eventuale attacco spiegando ad utenti e manager la tipologia di attacco e come evitare questi attacchi in futuro:

<https://app.any.run/tasks/d6f73302-d491-4f13-bbfb-caf67648c7d6/>

<https://app.any.run/tasks/70555e9b-3e91-4126-bb9e-567fcbeb0ac2/>

Caso 1

Descrizione attacco

Osserviamo l'apertura del documento data in formato PDF e che questo ha un link verso una pagina esterna. Questo documento PDF contiene un attacco di spear phishing. Questa tipologia di attacco è una forma mirata di phishing che si differenzia dal phishing generico per il suo approccio personalizzato e diretto verso individui o organizzazioni specifici. A differenza del phishing tradizionale, che di solito invia messaggi di massa a molti destinatari con l'intento di attrarre qualche vittima, lo spear phishing si concentra su una singola persona o su un gruppo ristrettamente definito. Il documento contiene un link che reindirizza a un sito web fasullo progettato probabilmente per raccogliere informazioni personali o di accesso dagli utenti.

Impatto Potenziale: Il documento potrebbe compromettere la sicurezza del sistema eseguendo codice malevolo, raccogliendo informazioni sensibili o aprendo canali per ulteriori attacchi.

Indicazioni di Sicurezza:

- **Non aprire il documento** se non sei sicuro della sua provenienza.
- **Non eseguire o interagire con** il documento o i suoi componenti.
- **Eseguire una scansione completa** del sistema con un software antivirus o anti-malware aggiornato.

Caso 2

Descrizione attacco

Il documento ha creato un file eseguibile subito dopo l'apertura. Questo file eseguibile è il componente principale di un malware. Il software malevolo in questione è **Phobos**, un ransomware/stealer che blocca o codifica i file per richiedere un riscatto e rubare informazioni sensibili. Usa tecniche complesse di codifica che non lascia possibilità di recuperare i file infetti.

Impatto Potenziale: Il ransomware può compromettere gravemente il tuo sistema, cifrare file importanti e richiedere un riscatto per decrittografarli. Inoltre, potrebbe rubare dati personali sensibili.

Indicazioni di Sicurezza:

- **Non aprire** il documento se sospetti che possa essere malevolo.
- **Esegui una scansione completa del sistema** con un software antivirus aggiornato.
- **Esegui il backup dei dati** regolarmente e mantieni le copie di sicurezza offline per proteggerle da attacchi di ransomware.
- **Ripristina il sistema** da un backup sano se sei stato infettato e il malware ha cifrato i tuoi file